2026 INTERNATIONAL FINTECH COMPETITION / TOPIC C

Security Self-Assessment

Permission levels, implemented controls and known risks

Transparent statement of the limits of the current financial MVP: no real-money movement, unverified user-entered quotes, no authentication, and no automatic regulatory certification.

StudentBridge AI · China · United Kingdom · Japan · South Korea · Australia · Bangladesh

Prepared 15 October 2026 · Demonstration system · Real references with conditional user-input quotes

Security Self-Assessment — StudentBridge AI Competition MVP

Date: 15 October 2026 | Scope: local demonstration / **no real money**

1. Permission model (implemented scope)

- **Read-only, anonymous:** view public source registry, institutional catalog, formal visa / survey facts, country credit guidance.
- **Planner user:** enter invoice and student budget, enter user-supplied quotes, run calculations, generate Decision Passport. The demo has no shared user identity; do not upload private financial files.
- **Sandbox approver:** explicitly review and confirm an approved test quote, supply the approval phrase, receive a local simulated record. A failed route cannot be executed in the sandbox.
- **Local operator:** configures server secrets, manages local logs and optional LLM key. Not exposed as a browser control.
- **AI agent:** read-only financial explanation from approved tool outputs. It has no permission to call `/api/sandbox/execute`, transact money, or change underlying calculations.

2. Implemented controls

Input schemas and safe numeric bounds with Pydantic; country/currency validation; SHA256 plan fingerprint; Decimal-based calculations; refusal when deadline, budget or user-asserted eligibility fail; quote expiration; no real bank API; manual approval phrase + explicit checkbox; unique idempotency keys (duplicate prevention); parameterized MySQL SQL through SQLAlchemy; transactional HMAC-linked audit events with serialized InnoDB chain updates; PDF magic, page and size checks; invoice text never executed as agent instructions; HTML client output escapes untrusted dynamic values; source provenance labels.

3. Known risk register

Risk	Severity	Current control	Residual risk
User-submitted quote unverified	High	All quotes clearly labeled unverified, missing source flagged	No independent bank/provider quote verification
Corridor regulatory eligibility unknown	High	Eligibility is user-attested, warnings everywhere	Cannot certify legal route compliance
Inaccurate/incomplete fees	High	Explicit quote inputs and transparency	Unknown intermediary/ beneficiary charges
Live FX unavailable or stale	Medium	API observation date and unavailable state	No offline fully verified bank rate snapshot
No authentication and role separation	High	Localhost-bound demo, no real accounts/funds	**Not deployable as production multi-user system**

Risk	Severity	Current control	Residual risk
MySQL DB can contain entered student information	High	Guidance not to enter real personal data	No encryption-at-rest/retention controls
Fraudulent invoice / recipient change	High	PDF data treated as untrusted; manual verification	No authoritative beneficiary or fraud verification
Prompt injection in PDF	Medium	No AI instruction execution from PDF; conservative extraction	In advanced OCR/LLM pipelines more filters needed
Sandbox approval abuse	Medium	Explicit approval and idempotency	No authenticated per-user consent/authorization
Key/secret exposure	High	Optional key via environment; `.gitignore`	Default local HMAC key must be replaced
Data poisoning / license risk	Medium	Source registry with official links	Source terms and updates require human review
External FX API outage	Low	Honest unavailable state, no fabricated rates	Live planning reduced

4. Recommended production remediation before real users

User authentication and session isolation; role permissions and access policy engine; TLS and secure cookies; encrypted storage, data minimization and deletion; secrets manager/rotations; rate limits, file AV/scanning and object storage; provider contract and secure quote APIs; verified payout/recipient onboarding; actual KYC/AML/sanctions and regional legal counsel; bank-grade approval authorization; anti-fraud signals; independent security audit; external immutable audit attestation; monitoring, backups and incident response.

5. Honest user protection notice

No real customer funds are transferred in StudentBridge AI. An audit event reading `SIMULATED_COMPLETED` means a local test ledger row was created. It does not prove a real bank transfer, licensed compliance, or successful settlement. The HMAC chain helps reveal local alteration but has not been externally certified. This proof-of-concept must not be marketed as compliant financial execution software.

6. MySQL migration and residual concerns

MySQL writes are transactional, with uniqueness-enforced idempotency and `SELECT ... FOR UPDATE` chain-head locking. The audit record and sandbox transaction are committed together. The service has no per-user sign-in or permission isolation; browser-accessible history and audit views are not appropriate for an Internet-facing deployment. Restrict access to a private demonstration environment, use a managed secrets store, TLS, least-privilege MySQL login, backups and retention rules. Set a stable, high-entropy `APP_SECRET`; changing this key invalidates existing audit-chain verification. Unit tests use disposable SQLite only; a MySQL integration smoke test is still required.